Microsoft Defender for Cloud — CSPM & Secure Score Remediation — Government (GCC High)

Implementation Solution Guide

Version 1.0.0 · 2026-07-10

Contents

Executive Summary — Microsoft Defender for Cloud: CSPM & Secure Score Remediation 5

What you get . . . 5

What this delivers . . . 5

The standard deployment model . . . 6

Boundary . . . 6

Effort . . . 6

1. Solution Overview — Microsoft Defender for Cloud: CSPM & Secure Score Remediation 6

What Microsoft Defender for Cloud (CSPM) is . . . 6

Why this matters . . . 7

How it works . . . 7

What you can control . . . 7

Limitations (be honest with buyers) . . . 7

Connections and authentication used (GCC High / Azure Government) . . . 8

The standard deployment model . . . 8

2. Requirements Guide — Microsoft Defender for Cloud: CSPM & Secure Score Remediation 8

2.1 At least one Azure subscription and a pilot scope . . . 9

2.2 Rights to enable plans and manage governance . . . 9

2.3 Defender CSPM plan decision (paid) . . . 9

2.4 Resource providers registered . . . 9

2.5 Log Analytics workspace for continuous export . . . 10

2.6 Regulatory-standard selection (compliance owns the choice) . . . 10

2.7 Agentless scanning prerequisites . . . 10

2.8 Multicloud connector decision (AWS/GCP, optional) . . . 10

2.9 Change control, pilot scope, and rollback . . . 10

Checklist . . . 11

Global Requirements — Defender (category-level) 11

G1. Microsoft 365 / Entra tenant . . . 11

G2. Defender licensing . . . 11

G3. Administrative roles (least privilege) . . . 11

G4. Onboarding reach to endpoints / identity / workloads . . . 12

G5. Network access to Defender service endpoints . . . 12

G6. A pilot ring . . . 12

G7. Log Analytics workspace (where required) . . . 12

G8. Response governance . . . 12

GCC High Parity Notes — Microsoft Defender for Cloud: CSPM & Secure Score Remediation 12

National cloud endpoints . . . 13
Feature-parity considerations . . . 13
Compliance & data-residency context (why GCC High) . . . 14
DoD (IL5) note . . . 15
3. Implementation Guide — Microsoft Defender for Cloud: CSPM & Secure Score Remediation
Naming (set once, reuse verbatim) . . . 15
Step 1 — Assess current posture . . . 16
Step 2 — Enable Defender CSPM on the pilot subscription . . . 16
Step 3 — Turn on agentless scanning . . . 16
Step 4 — Enable the regulatory-compliance dashboard . . . 16
Step 5 — Work recommendations in priority order . . . 17
Step 6 — Set governance rules and exemptions . . . 17
Step 7 — Configure continuous export . . . 17
Step 8 — Validate on the pilot . . . 17
Step 9 — Expand across the estate (and multicloud) . . . 18
5. Testing Guide — Microsoft Defender for Cloud: CSPM & Secure Score Remediation 18
Test 1 — Defender CSPM enabled . . . 18
Test 2 — Agentless scanning on . . . 18
Test 3 — Regulatory-compliance dashboard renders . . . 18
Test 4 — Secure Score moved after remediation . . . 19
Test 5 — Attack paths queryable . . . 19
Test 6 — Governance rule and exemptions in place . . . 19
Test 7 — Continuous export flowing . . . 19
Test 8 — Posture baseline saved for trending . . . 19
6. Troubleshooting Guide — Microsoft Defender for Cloud: CSPM & Secure Score Remediation
Defender CSPM not enabling . . . 20
No agentless scan results . . . 20
Compliance dashboard empty . . . 20
Secure Score not moving . . . 20
No attack-path data . . . 20
Exemption without expiry . . . 21
Continuous export no data . . . 21
Secure Score empty . . . 21
Script cannot authenticate or query Resource Graph . . . 21
7. Best Practices — Microsoft Defender for Cloud: CSPM & Secure Score Remediation 21
Enable on a pilot subscription, then inherit at management-group scope . . . 21

Remediate by risk, not by count . . . 21
Treat Secure Score as a trend . . . 22
Make exemptions honest and time-bound . . . 22
Assign ownership with governance rules . . . 22
Export continuously and report the trend . . . 22
Keep licensing and preview facts current (GCC High/DoD parity) . . . 22
Defer the compliance and risk decisions to the owners . . . 22
Where to go next . . . 23
8. Deliverables Summary — Microsoft Defender for Cloud: CSPM & Secure Score Remediation
Documentation . . . 23
PowerShell scripts (Az + KQL / Azure Resource Graph) . . . 24
What the buyer receives . . . 24
Outcome . . . 24
Appendix A — PowerShell Scripts 25

Executive Summary — Microsoft Defender for Cloud: CSPM & Secure Score Remediation

White-label · Defender · Government (GCC High) edition

This is the **Government (GCC High)** edition for US public-sector and defense-industrial-base tenants operating in **Microsoft Azure Government / GCC High**. It mirrors the commercial method exactly, adapted for the sovereign cloud — the Azure Government portal (`portal.azure.us`), the GCC High security portal (`security.microsoft.us`), Azure Government sign-in (`login.microsoftonline.us`), and PowerShell targeting the US Gov cloud (`Connect-AzAccount -Environment AzureUSGovernment`). Because feature, plan, and preview parity in GCC High/DoD can **lag commercial**, every availability and pricing claim is flagged to **verify against current Microsoft Government documentation** (see the included `gcc-high-parity-notes.md`).

Cloud misconfiguration is the leading cause of cloud breaches, and most teams have **no continuous view** of it — they find out at audit time, or after an incident. This solution turns on **Microsoft Defender for Cloud** (foundational CSPM plus **Defender CSPM**), enables **agentless machine scanning** and the **regulatory-compliance dashboard**, and — most importantly — gives you a **prioritized remediation program** that measurably raises **Secure Score** across Azure, with **AWS/GCP connectors** extending posture to a multicloud estate.

This is a complete, **deploy-it-today** package written for an administrator with no prior Defender for Cloud experience. It enables posture management on a **pilot subscription first**, keeps every change **preview/**`-WhatIf` **first**, and defers regulatory determinations to the compliance function.

What you get

- A plain-language **Solution Overview** of Defender for Cloud, foundational vs Defender CSPM, Secure Score, agentless scanning, attack paths, and multicloud connectors.
- A **Requirements Guide** with verify / implement-if-missing for every solution-specific prerequisite.
- An **Implementation Guide** of exact, ordered portal steps — enable CSPM, turn on agentless scanning and the compliance dashboard, work the prioritized recommendations, and set governance rules and continuous export, pilot-first.
- Five **PowerShell scripts** (Az) plus **KQL/Azure Resource Graph** queries for posture discovery, CSPM validation, a Secure-Score + attack-path report with drift, a `-WhatIf`-gated CSPM-enable helper, and a recommendation/attack-path hunt.
- **Testing** and **Troubleshooting** guides for a confident rollout.

What this delivers

Microsoft Defender for Cloud enabled (foundational CSPM free tier and the paid **Defender CSPM** plan), **agentless scanning** and the **regulatory-compliance dashboard** turned on, a **prioritized remediation cadence** driven by risk (attack paths, recommendation impact) that raises **Secure Score**, **governance rules and exemptions** so ownership and exceptions are tracked, **continuous export** to a Log Analytics workspace/workbook for trending, and **AWS/GCP connectors** for high-level multicloud posture — all proven on a pilot subscription first.

The standard deployment model

Assess → **Configure** → **Pilot** → **Validate** → **Expand** — enable and validate on a pilot subscription, then expand across the estate.

Boundary

This solution delivers the **technical posture-management configuration and remediation cadence**. Which regulatory standards apply, which records/legal obligations must be met, and whether a given exemption is acceptable are **the customer's compliance, legal, and security functions'** determinations — this guide provides the controls and the evidence, not the decision. Some plans/features are **paid** and version-dependent — licensing facts are flagged **verify**.

Effort

A competent administrator can enable CSPM and establish the remediation cadence on a pilot subscription in a focused engagement, then expand per subscription. Multicloud connectors and agentless scanning scale with estate size.

1. Solution Overview — Microsoft Defender for Cloud: CSPM & Secure Score Remediation

> ***Government (GCC High) edition.*** *This is the US Government national-cloud edition for public-sector and defense-industrial-base (DIB) tenants running in* ***Microsoft Azure Government / GCC High****. It mirrors the commercial method exactly, adapted for the sovereign cloud: the Azure Government portal (*`portal.azure.us`*), the GCC High Defender/unified-security portal (*`security.microsoft.us`*), Azure Government sign-in (*`login.microsoftonline.us`*), and PowerShell targeting the US Gov cloud (*`Connect-AzAccount -Environment AzureUSGovernment`*). Feature and plan parity in GCC High/DoD can* ***lag commercial*** *— every availability/pricing/preview claim must be* ***verified against current Microsoft Government documentation*** *(see* `gcc-high-parity-notes.md`*).*

What Microsoft Defender for Cloud (CSPM) is

Microsoft Defender for Cloud is Azure's **cloud security posture management (CSPM)** and workload-protection service. Its posture-management side continuously assesses your cloud resources against a security baseline and expresses the result as a single **Secure Score**, a set of prioritized **recommendations**, a **regulatory-compliance** view, and — with the paid **Defender CSPM** plan — **agentless scanning**, **attack-path analysis**, and **cloud security graph** risk hunting. It has two posture tiers:

- **Foundational CSPM** — free, on by default for Azure subscriptions. Provides Secure Score, security recommendations, and asset inventory.
- **Defender CSPM** — a paid plan that adds agentless machine/vulnerability scanning, **attack-path analysis**, the cloud security graph (risk hunting), governance rules at scale, and data-aware posture.

Defender for Cloud also connects to **AWS and GCP** via connectors, so one posture view and one prioritized recommendation list can span a multicloud estate.

Why this matters

Most cloud breaches trace back to a **misconfiguration** — public storage, an over-permissive network rule, an unencrypted disk, a missing MFA requirement — not a zero-day. The problem is that teams have no *continuous* view of those misconfigurations; they surface at audit time or after an incident. Defender for Cloud turns that into a live, scored, prioritized picture: it tells you exactly what is wrong, ranks it by real risk (an **attack path** that chains an internet-exposed VM to a privileged identity to sensitive data is worse than an isolated low-severity finding), and lets you track a **Secure Score** that trends upward as you remediate. The goal is a managed posture with a **remediation cadence** that measurably raises the score — not a static, once-a-year audit — proven on a pilot subscription before it is applied everywhere.

How it works

1. **Foundational CSPM** is confirmed on the pilot subscription and the starting **Secure Score** is recorded.

2. **Defender CSPM** (paid) is enabled on the pilot subscription to unlock **agentless scanning**, **attack-path analysis**, and risk hunting. *Plan availability and pricing — verify current in your tenant.*

3. **Agentless machine scanning** turns on so VMs and disks are assessed for vulnerabilities and misconfigurations without installing an agent.

4. The **regulatory-compliance dashboard** is enabled and mapped to the standard(s) the organization must meet (the *choice* of standard is the compliance team's).

5. **Recommendations are worked in priority order** — highest-impact and attack-path-linked items first, using the built-in **Fix** action where offered — and the Secure Score is tracked each cycle.

6. **Governance rules** assign owners and due dates to recommendations, and **exemptions** record justified, time-bound exceptions (never silent suppression).

7. **Continuous export** streams recommendations and Secure Score to a **Log Analytics workspace** and a **workbook** for long-term trending and reporting.

8. **AWS/GCP connectors** extend the same posture model to multicloud, at a high level.

What you can control

• **Posture tier** — foundational CSPM (free) vs Defender CSPM (paid) per subscription/connector.

• **Agentless scanning** — on/off and scope for VM/disk vulnerability and misconfiguration assessment.

• **Remediation priority** — which recommendations and attack paths to fix first, and the cadence.

• **Governance** — owners, due dates, and grace periods via governance rules; justified exemptions with expiry.

• **Reporting** — continuous export destinations (Log Analytics/workbook) and the compliance standards displayed.

• **Scope** — which subscriptions and which clouds (Azure/AWS/GCP) are covered.

Limitations (be honest with buyers)

• **Defender CSPM, agentless scanning, and several plans are paid** per resource/subscription; foundational CSPM (free) gives Secure Score and recommendations only. *Verify current plan pricing and availability in your tenant.*

• Secure Score and recommendations are **not instantaneous** — assessments take time to populate after enabling; allow a warm-up window.

• A recommendation being "Fixed" reflects the current assessment; posture **drifts** as new resources are created — this is why the cadence and continuous export matter.

• Multicloud (AWS/GCP) coverage here is **high-level posture**; deep per-cloud workload protection is a larger, separate effort. **In GCC High/DoD, multicloud connectors, agentless scanning, data-aware posture, and specific Defender plans may be delayed or unavailable — verify against current Microsoft Government documentation before assuming a feature is present.**

• CSPM reduces misconfiguration risk; it does not replace patching, backup, identity hardening, or the security team's risk decisions.

Connections and authentication used (GCC High / Azure Government)

• The **Azure Government portal** (`https://portal.azure.us`) → **Microsoft Defender for Cloud** for plans, Secure Score, recommendations, attack paths, compliance, governance, and export. The unified-security/Defender portal in GCC High is `https://security.microsoft.us`.

• Sign-in / token host: `login.microsoftonline.us` (Azure Government).

• **Az PowerShell** (`Az.Accounts`, `Az.Security`, `Az.ResourceGraph`, `Az.Resources`) for read-only discovery, validation, reporting, and Resource Graph (KQL) hunting — connect with `Connect-AzAccount -Environment AzureUSGovernment` so every call targets the US Gov cloud.

• A **Log Analytics workspace** as the continuous-export destination (per `global-requirements-defender.md` G7).

• **AWS/GCP connectors** for multicloud posture.

• Least-privilege roles: **Security Reader** for read-only work, **Security Admin** (or Owner/Contributor at scope) for enabling plans and governance.

The standard deployment model

> ***Assess current posture (plans, Secure Score, recommendations) → configure (enable Defender CSPM, agentless scanning, compliance dashboard) → pilot on one subscription → validate remediation raises Secure Score → expand across subscriptions and to AWS/GCP.*** *Repeatable pattern:* ***Assess → Configure → Pilot → Validate → Expand****, every change preview/*`-WhatIf` *first.*

2. Requirements Guide — Microsoft Defender for Cloud: CSPM & Secure Score Remediation

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant, licensing, admin roles, network access, pilot

scope, workspace, response governance) are in `global-requirements-defender.md` — do not repeat them; the items below are **specific to enabling Defender for Cloud CSPM and running a Secure-Score remediation program**. Objects are named `<Purpose> – <Scope> – <Stage>` and reused verbatim in every later step, script, and test.

> ***Government (GCC High) edition.*** *All portal verification is in the* ***Azure Government portal*** *(`portal.azure.us`); the GCC High security portal is `security.microsoft.us`; sign-in is `login.microsoftonline.us`; scripts connect with `Connect-AzAccount -Environment AzureUSGovernment`.* ***Feature and plan parity in GCC High/DoD can lag commercial*** *— Defender CSPM, agentless scanning, data-aware posture, attack-path analysis, and AWS/GCP connectors* ***may be delayed or unavailable****. Do* ***not*** *assume a feature exists;* ***verify each against current Microsoft Government documentation*** *for your specific cloud (GCC High vs DoD/IL5). See `gcc-high-parity-notes.md` for the endpoint table and parity considerations.*

2.1 At least one Azure subscription and a pilot scope

Description: An Azure subscription under the Entra tenant, and a decision on the **pilot subscription** to onboard first: `CSPM Scope – Pilot Sub – Pilot`. **Why:** Defender for Cloud plans, Secure Score, and recommendations operate per subscription; the pilot limits blast radius and cost while you validate. **Verify:** `portal.azure.us` → **Subscriptions**; run `DEFCSPMG-Discovery.ps1` to list subscriptions and current plan status. **Implement-if-missing:** Create/associate a subscription and choose the pilot subscription.

2.2 Rights to enable plans and manage governance

Description: Security Admin (plus **Owner** or **Contributor** at the subscription for plan changes and remediation), and **Security Reader** for read-only reporting accounts. **Why:** Enabling Defender CSPM, agentless scanning, governance rules, and continuous export requires these rights; reporting only needs read. **Verify:** Azure → **Access control (IAM)** at the pilot subscription; `DEFCSPMG-Discovery.ps1` reports the running account's effective access. **Implement-if-missing:** Assign the minimum roles at the narrowest scope; prefer PIM eligible activation over standing access.

2.3 Defender CSPM plan decision (paid)

Description: A decision to enable the paid **Defender CSPM** plan (for agentless scanning, attack paths, risk hunting) versus staying on free foundational CSPM. **Why:** Attack-path analysis, agentless scanning, and the security graph are **Defender CSPM** features; foundational CSPM alone gives Secure Score and recommendations only. **Verify:** `portal.azure.us` → **Microsoft Defender for Cloud** → **Environment settings** → **<subscription>** → **Defender plans**; `DEFCSPMG-Discovery.ps1` reports plan tiers. *Verify current Defender CSPM pricing and availability in your tenant.* **Implement-if-missing:** Enable Defender CSPM on the pilot subscription (Implementation Step 2); keep it scoped to the pilot until validated.

2.4 Resource providers registered

Description: The **Microsoft.Security** resource provider (and **Microsoft.PolicyInsights** for the underlying assessments) registered on the subscription. **Why:** Defender for Cloud assessments and Secure Score require the providers registered. **Verify:** Azure → **Subscriptions** → **Resource providers** shows **Microsoft.Security** as Registered; `DEFCSPMG-Validate.ps1` checks this. **Implement-if-missing:** Register the provider (`Register-AzResourceProvider -ProviderNamespace`

`Microsoft.Security`).

2.5 Log Analytics workspace for continuous export

Description: A Log Analytics workspace to receive **continuous export** of recommendations and Secure Score: destination for `CSPM Continuous Export – Pilot Sub – Prod`. **Why:** Long-term trending, workbooks, and integration land in a workspace (per `global-requirements-defender.md` G7). **Verify:** `portal.azure.us` → **Log Analytics workspaces**; `DEFCSPMG-Discovery.ps1` reports available workspaces. **Implement-if-missing:** Provision a workspace (or reuse the SIEM/observability one) with least-privilege access.

2.6 Regulatory-standard selection (compliance owns the choice)

Description: The regulatory standard(s) to display in the **regulatory-compliance dashboard** (e.g. a cloud security benchmark plus any required framework). **Why:** The dashboard maps posture to a standard; without a selected standard there is nothing to measure against. **Verify:** `portal.azure.us` → **Microsoft Defender for Cloud** → **Regulatory compliance** → **Manage compliance policies**; confirm the standard(s) assigned. **Implement-if-missing:** Assign the Microsoft cloud security benchmark by default; **which additional standards apply is the compliance/legal team's determination** — add those they specify.

2.7 Agentless scanning prerequisites

Description: The permissions and scope for **agentless machine scanning** (part of Defender CSPM / Defender for Servers). **Why:** Agentless scanning assesses VMs/disks without an agent but requires the plan and permission to snapshot/scan. **Verify:** `portal.azure.us` → **Environment settings** → **<subscription>** → **Defender CSPM** → **Settings** shows agentless scanning availability; `DEFCSPMG-Validate.ps1` reports its state. *Verify current agentless scanning requirements.* **Implement-if-missing:** Enable agentless scanning in the Defender CSPM plan settings on the pilot subscription.

2.8 Multicloud connector decision (AWS/GCP, optional)

Description: Whether to extend posture to **AWS/GCP** via connectors, and the cloud accounts/roles required. **Why:** Multicloud posture requires a connector and a role/service account in the target cloud; it is optional and scoped separately. **Verify:** `portal.azure.us` → **Environment settings** → **Add environment (AWS/GCP)**; `DEFCSPMG-Discovery.ps1` lists existing connectors. **Implement-if-missing:** Add AWS/GCP connectors only after the Azure pilot is validated; keep to high-level posture at first.

2.9 Change control, pilot scope, and rollback

Description: An approved change record, the named pilot subscription, and a documented rollback before enabling paid plans or applying remediation broadly. **Why:** Paid plans incur cost and remediation changes real resources; the pilot-first, preview-first approach and rollback are the safety net. **Verify:** An approved change record, the pilot scope, and a written back-out (disable the plan / revert the change) exist. **Implement-if-missing:** Capture the current posture with `DEFCSPMG-Report.ps1 -SaveBaseline`, define the pilot scope, and write the rollback.

Checklist

- Azure subscription + pilot subscription chosen — `DEFCSPMG-Discovery.ps1`
- Security Admin + Owner/Contributor (change) and Security Reader (report) roles
- Defender CSPM (paid) plan decision made
- Microsoft.Security provider registered — `DEFCSPMG-Validate.ps1`
- Log Analytics workspace for continuous export
- Regulatory standard(s) selected (compliance owns the choice)
- Agentless scanning prerequisites confirmed
- Multicloud (AWS/GCP) connector decision made
- Change window, pilot scope, and rollback documented

Global Requirements — Defender (category-level)

These requirements apply to every solution in the Defender category (Microsoft Defender XDR and Defender for Cloud). Published once at the category level so listings stay small. Confirm before deploying any Defender solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *Defender changes touch detection and response for the whole tenant. Onboard in a ring (pilot devices/users first), keep automated response in an approval/simulate posture until trusted, and never disable an existing control to "test."*

G1. Microsoft 365 / Entra tenant

Description: An active Microsoft 365 tenant with Entra ID. Why: Defender XDR services and the unified portal (security.microsoft.com) are tenant workloads. Verify: Sign in to `https://security.microsoft.com` as an administrator. Implement: Provision a Microsoft 365 tenant and confirm Entra ID identities exist.

G2. Defender licensing

Description: The Defender plans for the pillars in scope — e.g. Defender for Endpoint P1/P2, Defender for Identity, Defender for Office 365 P1/P2, Defender for Cloud Apps, and Defender for Cloud plans. Why: Each pillar/feature is license-gated; onboarding without the plan fails or silently limits features. Verify: Admin center -> `Billing -> Licenses` (or the Defender portal). *Confirm the exact plan each feature needs — verify current availability in your tenant.* Implement: Assign the required plans (often bundled in M365 E5 / E5 Security) before onboarding.

G3. Administrative roles (least privilege)

Description: Security Administrator (and Global Administrator for first-time service activation). Why: Onboarding, RBAC, and policy changes in the Defender portal require these roles. Verify: Entra -> `Roles and administrators`; confirm Security Administrator. Implement: Assign Security Administrator;

reserve Global Administrator for one-time activations.

G4. Onboarding reach to endpoints / identity / workloads

Description: A management channel to onboard the pillars — Intune/Configuration Manager/GPO/script for endpoints, domain controllers/AD FS for Identity sensors, and cloud connectors for Defender for Cloud. Why: Each pillar collects signal from a source that must be reachable and instrumented. Verify: Endpoints are managed (Intune/CM); DCs are reachable; cloud subscriptions are connected. Run the solution's discovery script. Implement: Establish the onboarding channel per pillar (see the relevant catalog endpoint/identity solutions).

G5. Network access to Defender service endpoints

Description: Outbound HTTPS to the Microsoft Defender / Microsoft 365 service URLs from onboarded assets. Why: Sensors and agents report to the cloud service; blocked endpoints break onboarding and detections. Verify: Confirm the documented Defender endpoint URLs/IP ranges are allowed. *Verify current endpoint list.* Implement: Allow the Defender/M365 endpoints through proxy/firewall.

G6. A pilot ring

Description: A defined set of pilot devices/users/subscriptions to onboard first. Why: XDR onboarding and automated response are validated on a ring before tenant-wide rollout. Verify: A pilot group exists in Entra/Intune. Implement: Create the pilot ring before enabling anything that acts automatically.

G7. Log Analytics workspace (where required)

Description: A Log Analytics workspace for Defender for Cloud / advanced hunting export where used. Why: Some Defender data and continuous export land in a workspace. Verify: A workspace exists and is access-controlled. Run the discovery script. Implement: Provision a workspace (or reuse the SIEM/observability one) with least-privilege access.

G8. Response governance

Description: An agreed position on automated response (auto-remediation levels, approval requirements). Why: XDR/AIR can take disruptive actions (isolate, delete, disable); the organization must decide the guardrails. Verify: A documented response policy exists; automation is in an approval/simulate posture until trusted. Implement: Define response guardrails; keep AIR/automation approval-gated at first. *Incident-response decisions are the SOC/security team's; this guide covers the technical configuration.*

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

GCC High Parity Notes — Microsoft Defender for Cloud: CSPM & Secure Score Remediation

This document is specific to the **Government (GCC High)** edition of this solution. It records the US Government national-cloud endpoints this solution uses, the feature-parity considerations that differ from

commercial Azure, and the compliance/data-residency context that motivates GCC High. It does **not** assert availability or make an authorization decision — every version/preview/plan fact must be **verified against current Microsoft Government documentation** for your specific cloud (GCC High vs DoD/IL5), and accreditation determinations belong to your ISSO/compliance function.

National cloud endpoints

Purpose	Commercial (do **not** use here)	GCC High / Azure Government (use this)
Azure management portal	`portal.azure.com`	`portal.azure.us` (Azure Government)
Defender / unified security portal	`security.microsoft.com`	`security.microsoft.us`
Sign-in / token (Azure AD/Entra)	`login.microsoftonline.com`	`login.microsoftonline.us`
Microsoft Graph	`graph.microsoft.com`	`graph.microsoft.us` (GCC High) — DoD/IL5 uses `dod-graph.microsoft.us`; **verify your cloud**
Azure Resource Manager	`management.azure.com`	`management.usgovcloudapi.net` (Az PowerShell selects this via `-Environment AzureUSGovernment`)
Az PowerShell cloud	`Connect-AzAccount` (AzureCloud)	`Connect-AzAccount -Environment AzureUSGovernment`
Microsoft Graph PowerShell	`Connect-MgGraph`	`Connect-MgGraph -Environment USGov` (DoD: `-Environment USGovDoD`) — this solution is Az-based, noted for cross-reference

All five scripts (`DEFCSPMG-Discovery.ps1`, `DEFCSPMG-Validate.ps1`, `DEFCSPMG-Report.ps1`, `DEFCSPMG-Enable-CSPM.ps1`, `DEFCSPMG-Hunt.ps1`) default their connection to `Connect-AzAccount -Environment AzureUSGovernment`. If you authenticate manually, include that switch or the Az context targets commercial Azure and returns nothing for a Gov tenant.

Feature-parity considerations

GCC High and DoD frequently **lag commercial Azure** or lack features entirely. For this Defender for Cloud CSPM solution, treat each of the following as **"verify against current Microsoft Government documentation"** before you rely on it — do not assume parity, and do not invent availability:

- **Defender CSPM plan (CloudPosture) availability and pricing** — the paid Defender CSPM plan and its

per-resource pricing may differ or arrive later in GCC High/DoD. *Verify current availability and pricing for your Gov tenant.*

- **Agentless machine/disk scanning** — snapshot-based agentless scanning may be delayed or region-

constrained in the sovereign cloud. *Verify it is available and supported in your Azure Government region.*

- **Attack-path analysis & cloud security graph (risk hunting)** — these Defender CSPM capabilities may

lag or behave differently in GCC High/DoD; `DEFCSPMG-Hunt.ps1 -Mode AttackPaths` may return nothing if the feature/graph is not yet available. *Verify.*

- **Data-aware security posture** — data-sensitivity discovery may be limited or unavailable. *Verify.*

- **AWS/GCP multicloud connectors** — cross-cloud connectors and the third-party clouds they reach are

often **not** available (or restricted) from GCC High/DoD. Do not plan multicloud posture on the assumption it works; *verify connector support for Azure Government first.*

- **Regulatory-compliance standards catalog** — the set of built-in compliance standards offered in the

regulatory-compliance dashboard can differ in Gov clouds (the Microsoft cloud security benchmark is generally present; government-specific standards vary). *Verify which standards are assignable.*

- **Preview features and newest capabilities** — anything in preview on commercial is likely **absent or

later** in GCC High/DoD. Do not depend on preview features for a Gov deployment. *Verify.*

- **Continuous export / Log Analytics** — supported in Azure Government, but confirm the workspace and

region are within your accreditation boundary. *Verify.*

Compliance & data-residency context (why GCC High)

GCC High exists to keep regulated US Government and defense-industrial-base workloads inside a US-sovereign, US-persons-operated boundary. Relevant context for this solution — provided as technical background, not as an authorization:

- **FedRAMP High** — GCC High is designed to support FedRAMP High workloads; confirm the current

authorization status and boundary for Defender for Cloud in your tenant.

- **DoD Impact Levels (IL4 / IL5)** — DoD workloads map to IL4/IL5 in Azure Government / GCC High-DoD.

Whether this deployment falls in scope, and at which impact level, is your **ISSO/compliance determination**, not this guide's.

- **CMMC 2.0** — DIB contractors handling CUI use GCC High to help meet CMMC/NIST SP 800-171 control

expectations. Posture management and Secure Score evidence support, but do not constitute, a CMMC assessment.

- **ITAR / EAR data-residency** — GCC High provides US-only data residency and US-persons support

needed for ITAR/EAR-controlled technical data. Confirm your data-handling obligations with your compliance/legal function.

• **US-persons handling** — GCC High operations personnel are screened US persons; if this is a contractual requirement, confirm it applies to every service in scope.

Boundary determinations — the accreditation boundary, applicable impact level, which standards apply, and whether a residual risk or exemption is acceptable — are the **customer's ISSO, compliance, legal, and security functions'** decisions. This solution provides the technical posture-management controls, scoring, and evidence, not the authorization.

DoD (IL5) note

DoD tenants (GCC High-DoD / IL5) differ from GCC High in specific endpoints and availability:

• **Microsoft Graph host is** `dod-graph.microsoft.us` (not `graph.microsoft.us`). This solution is Az-based, but any Graph-adjacent tooling must target the DoD host — **verify your cloud**.

• **Graph PowerShell** uses `Connect-MgGraph -Environment USGovDoD`; **Az PowerShell** still uses `-Environment AzureUSGovernment` for both GCC High and DoD.

• **Feature availability can lag GCC High further** at IL5 (Defender CSPM plan features, agentless scanning, attack paths, multicloud). **Verify each against current Microsoft Government documentation for the DoD cloud** before relying on it.

3. Implementation Guide — Microsoft Defender for Cloud: CSPM & Secure Score Remediation

Follow these steps **in order**, in the **Azure Government portal** (`https://portal.azure.us`) under **Microsoft Defender for Cloud**. The unified-security/Defender portal in GCC High is `https://security.microsoft.us`; sign-in is via `login.microsoftonline.us`. Objects are named `<Purpose> – <Scope> – <Stage>` and reused verbatim in every later step, script, and test.

> ***National cloud (GCC High):*** *all portal work happens in* ***Azure Government*** *(`portal.azure.us`), and the scripts connect with `Connect-AzAccount -Environment AzureUSGovernment`.* ***Defender CSPM plan availability, agentless scanning, data-aware posture, attack-path analysis, and AWS/GCP connectors may lag or be unavailable in GCC High/DoD — verify each against current Microsoft Government documentation before enabling.*** *DoD (IL5) tenants may differ further (e.g. `dod-graph.microsoft.us` for Graph); confirm your cloud.*
>
> ***Model:*** *Enable CSPM and agentless scanning on the* ***pilot subscription*** *first, understand the recommendation picture, remediate in priority order, and validate that Secure Score moves — then expand to the rest of the estate and to AWS/GCP. Every change is preview/`-WhatIf` first, and remediation of real resources is done in a controlled window with a rollback.* ***Which regulatory standards and which exemptions are acceptable are the compliance/security team's decisions.***

Naming (set once, reuse verbatim)

• Pilot scope (subscription): `CSPM Scope – Pilot Sub – Pilot`

• Governance rule (recommendation ownership): `Secure Score Remediation – Pilot Sub – Prod`

• Continuous export (to Log Analytics): `CSPM Continuous Export – Pilot Sub – Prod`

• Secure-Score trend workbook: `Secure Score Trend – Pilot Sub – Prod`

• Exemption (per justified exception): `CSPM Exemption – <recommendation> – Prod`

Step 1 — Assess current posture

1. `portal.azure.us` → **Microsoft Defender for Cloud** → **Overview**. Note the current **Secure Score** for the pilot subscription.

2. Run `DEFCSPMG-Discovery.ps1` to capture plan status per subscription, Secure Score, registered providers, available Log Analytics workspaces, and any existing AWS/GCP connectors.

3. Run `DEFCSPMG-Report.ps1 -SaveBaseline` to record the starting posture as the pre-change baseline.

Step 2 — Enable Defender CSPM on the pilot subscription

1. **Microsoft Defender for Cloud** → **Environment settings** → select `CSPM Scope – Pilot Sub – Pilot`.

2. On **Defender plans**, confirm **foundational CSPM** is on (free), then set **Defender CSPM** to **On**. *Verify current Defender CSPM pricing and availability in your tenant.*

3. Preview first: run `DEFCSPMG-Enable-CSPM.ps1 -SubscriptionId <pilot>` (defaults to `-WhatIf`) to see the change, then re-run with `-Apply` (or complete it in the portal).

4. **Save.** Allow time for the plan to activate and assessments to begin.

Step 3 — Turn on agentless scanning

1. Still in **Environment settings** → `CSPM Scope – Pilot Sub – Pilot` → **Defender CSPM** → **Settings**.

2. Enable **Agentless scanning for machines** (and data-aware/other toggles agreed in requirements). *Verify current agentless scanning requirements.*

3. **Save.** Agentless scans populate over time.

4. Run `DEFCSPMG-Validate.ps1` → confirms Defender CSPM is on and agentless scanning is enabled.

Step 4 — Enable the regulatory-compliance dashboard

1. **Microsoft Defender for Cloud** → **Regulatory compliance** → **Manage compliance policies** → select `CSPM Scope – Pilot Sub – Pilot`.

2. Confirm the **Microsoft cloud security benchmark** is assigned (default). Add any additional standard(s) **the compliance team specifies** — *the choice of standard is theirs, not this guide's.*

3. Return to **Regulatory compliance** and confirm the dashboard renders control pass/fail for the assigned standard(s).

Step 5 — Work recommendations in priority order

1. **Microsoft Defender for Cloud** → **Recommendations**. Sort by **risk / impact**; work the highest-impact items first.

2. **Attack path analysis** (Defender CSPM) → open **Attack paths** and prioritize any path that chains exposure → identity → sensitive data. Remediate the choke points first.

3. Use the built-in **Fix** action where offered. For manual fixes, do them in a controlled window with a rollback.

4. Re-run `DEFCSPMG-Report.ps1` after a remediation batch to confirm Secure Score is moving and to see the new top items.

Step 6 — Set governance rules and exemptions

1. **Microsoft Defender for Cloud** → **Governance rules** → **Create governance rule** → name it `Secure Score Remediation – Pilot Sub – Prod`. Assign **owners** and a **due date / grace period** for recommendations so accountability is tracked.

2. For any legitimate exception, create a scoped **Exemption** on the specific recommendation, named `CSPM Exemption – <recommendation> – Prod`, with a **justification and expiry** — never silently suppress. *Whether an exemption is acceptable is the security/compliance team's decision.*

3. Run `DEFCSPMG-Validate.ps1` → confirms the governance rule exists and exemptions are time-bound.

Step 7 — Configure continuous export

1. **Microsoft Defender for Cloud** → **Environment settings** → `CSPM Scope – Pilot Sub – Pilot` → **Continuous export**.

2. Create the export `CSPM Continuous Export – Pilot Sub – Prod` → export **Security recommendations** and **Secure Score** to the Log Analytics workspace from requirements.

3. (Optional) Deploy the **Secure Score over time** workbook and save it as `Secure Score Trend – Pilot Sub – Prod`.

4. Run `DEFCSPMG-Hunt.ps1` to confirm recommendations/attack-path data is queryable via Azure Resource Graph.

Step 8 — Validate on the pilot

1. Run `DEFCSPMG-Validate.ps1` → confirms Defender CSPM on, agentless scanning on, provider registered, governance rule present, continuous export configured.

2. Run `DEFCSPMG-Report.ps1 -BaselinePath .\defcspm-baseline.json` → confirms Secure Score has moved versus the Step 1 baseline and shows remaining top recommendations/attack paths.

3. Complete the **Testing Guide** before expanding.

Step 9 — Expand across the estate (and multicloud)

1. Enable Defender CSPM and agentless scanning on the remaining subscriptions (ideally at a **management-group** scope so new subscriptions inherit it).
2. Roll the governance rule, exemptions discipline, and continuous export out to those subscriptions.
3. (Optional) Add **AWS/GCP connectors** (**Environment settings** → **Add environment**) for high-level multicloud posture, after the Azure pilot is validated.
4. Re-baseline with `DEFCSPMG-Report.ps1 -SaveBaseline` and track Secure-Score/recommendation drift each cycle.

Order of operations

`Assess posture → enable Defender CSPM (pilot) → agentless scanning → compliance dashboard → remediate by priority → governance rules & exemptions → continuous export → validate Secure Score moved → expand (+ AWS/GCP)`

5. Testing Guide — Microsoft Defender for Cloud: CSPM & Secure Score Remediation

Run these checks after enabling CSPM and completing a first remediation batch on the pilot subscription (Implementation Steps 2–8), and again after each expansion wave. Each test has a **pass/fail gate**; do not expand across the estate until the pilot passes. Objects are referenced by the exact names from the Implementation Guide.

Test 1 — Defender CSPM enabled

Procedure: Run `DEFCSPMG-Validate.ps1`. In **Environment settings** → `CSPM Scope – Pilot Sub – Pilot` → **Defender plans**, confirm **Defender CSPM = On** (and foundational CSPM on). **Pass:** Defender CSPM is on for the pilot subscription. **Fail:** Plan shows Off/Free — re-run Implementation Step 2; see Troubleshooting *Defender CSPM not enabling*.

Test 2 — Agentless scanning on

Procedure: Run `DEFCSPMG-Validate.ps1` and confirm agentless scanning is enabled under Defender CSPM settings. **Pass:** Agentless scanning is enabled and (allowing warm-up) machine assessments appear. **Fail:** Disabled or no assessments — see Troubleshooting *No agentless scan results*.

Test 3 — Regulatory-compliance dashboard renders

Procedure: `portal.azure.us` → **Regulatory compliance**. Confirm the assigned standard(s) render control pass/fail for the pilot subscription. **Pass:** The dashboard shows the assigned standard with control status. **Fail:** Empty or no standard assigned — confirm Step 4; see Troubleshooting *Compliance dashboard empty*.

Test 4 — Secure Score moved after remediation

Procedure: Run `DEFCSPMG-Report.ps1 -BaselinePath .\defcspm-baseline.json`. Compare the current Secure Score to the Step 1 baseline after your first remediation batch. **Pass:** Secure Score is **higher** than the baseline (or the remaining recommendations are demonstrably lower risk). **Fail:** No movement — confirm the fixes applied and allow re-assessment time; see Troubleshooting *Secure Score not moving*.

Test 5 — Attack paths queryable

Procedure: Run `DEFCSPMG-Hunt.ps1 -Mode AttackPaths`. Confirm attack-path / risk data returns via Azure Resource Graph. **Pass:** Attack-path or high-risk recommendation data is returned (Defender CSPM active). **Fail:** No data — confirm Defender CSPM is on and allow warm-up; see Troubleshooting *No attack-path data*.

Test 6 — Governance rule and exemptions in place

Procedure: Run `DEFCSPMG-Validate.ps1`. In **Governance rules**, confirm `Secure Score Remediation – Pilot Sub – Prod` exists; in **Recommendations** → **Exemptions**, confirm any exemption is named `CSPM Exemption – <recommendation> – Prod` with a justification and **expiry**. **Pass:** The governance rule assigns owners/due dates and every exemption is time-bound and justified. **Fail:** No governance rule, or a permanent/unjustified exemption — see Troubleshooting *Exemption without expiry*.

Test 7 — Continuous export flowing

Procedure: Run `DEFCSPMG-Validate.ps1`. In the Log Analytics workspace, confirm `SecurityRecommendation` / Secure Score data is arriving from `CSPM Continuous Export – Pilot Sub – Prod`. **Pass:** Recommendation and Secure Score data land in the workspace. **Fail:** No data — confirm the export config and workspace permissions; see Troubleshooting *Continuous export no data*.

Test 8 — Posture baseline saved for trending

Procedure: Run `DEFCSPMG-Report.ps1 -SaveBaseline`. Confirm the current Secure Score and recommendation counts are written to the baseline file. **Pass:** A posture baseline exists to trend against each cycle. **Fail:** No score returned — allow assessment warm-up, then re-run; see Troubleshooting *Secure Score empty*.

Exit gate

All eight tests pass on the pilot subscription **before** any estate-wide or multicloud expansion (Implementation Step 9). Re-run Tests 1–4, 7, and 8 after each expansion wave and compare against the saved baseline.

6. Troubleshooting Guide — Microsoft Defender for Cloud: CSPM & Secure Score Remediation

Common field issues, in **symptom** → **cause** → **fix** form. Run `DEFCSPMG-Discovery.ps1` and `DEFCSPMG-Validate.ps1` first — most causes surface there.

Defender CSPM not enabling

Symptom: The Defender CSPM plan stays **Off/Free** after saving, or the save fails. **Cause:** The account lacks **Security Admin / Owner** at the subscription, the **Microsoft.Security** provider is not registered, or the plan is not available in the region/tenant. **Fix:** Confirm the running account's rights at `CSPM Scope – Pilot Sub – Pilot`; register the provider (`Register-AzResourceProvider -ProviderNamespace Microsoft.Security`); *verify Defender CSPM availability and pricing in your tenant*. Preview with `DEFCSPMG-Enable-CSPM.ps1 -WhatIf`, then `-Apply`, and re-run `DEFCSPMG-Validate.ps1`.

No agentless scan results

Symptom: Agentless scanning is enabled but no machine vulnerability/misconfiguration assessments appear. **Cause:** Not enough time has passed for the first scan, Defender CSPM is not actually active, or the scanning permissions/scope are missing. **Fix:** Allow warm-up time (scans populate over hours); confirm Defender CSPM is on (Test 1); *verify current agentless scanning requirements* and re-enable in the plan settings. Re-run `DEFCSPMG-Validate.ps1`.

Compliance dashboard empty

Symptom: Regulatory compliance shows no controls or no standard. **Cause:** No standard is assigned to the subscription, or assessments have not populated yet. **Fix:** Assign the Microsoft cloud security benchmark (and any standard the compliance team specifies) under **Manage compliance policies** (Implementation Step 4); allow assessment time. *The choice of standard is the compliance team's.*

Secure Score not moving

Symptom: After remediating recommendations, Secure Score is unchanged. **Cause:** The fix has not been re-assessed yet, the "fixed" resource still fails a related control, or the remediated recommendation carries little score weight. **Fix:** Allow re-assessment time; confirm the fix in **Recommendations** shows the resource as healthy; prioritize **higher-weight / attack-path** recommendations (they move the score more). Re-run `DEFCSPMG-Report.ps1 -BaselinePath .\defcspm-baseline.json`.

No attack-path data

Symptom: `DEFCSPMG-Hunt.ps1 -Mode AttackPaths` returns nothing. **Cause: Defender CSPM** is not enabled (attack paths are a Defender CSPM feature), or the security graph has not built yet. **Fix:** Confirm Defender CSPM is on (Test 1); allow warm-up time for the cloud security graph; re-run the hunt. If still empty, verify the plan in the portal.

Exemption without expiry

Symptom: A recommendation is exempted permanently or without justification. **Cause:** An exemption was created without an expiry/justification, creating a silent blind spot. **Fix:** Edit the exemption to add a justification and an **expiry**, and name it `CSPM Exemption – <recommendation> – Prod`. Review exemptions on a cadence. *Whether the exemption is acceptable is the security/compliance team's decision.*

Continuous export no data

Symptom: The Log Analytics workspace receives no recommendation/Secure Score data. **Cause:** The export `CSPM Continuous Export – Pilot Sub – Prod` is misconfigured, points at the wrong workspace, or the identity lacks write permission. **Fix:** Confirm the export config, workspace, and exported data types (recommendations + Secure Score); confirm workspace permissions; allow ingestion time. Re-run `DEFCSPMG-Validate.ps1` and query the workspace.

Secure Score empty

Symptom: `DEFCSPMG-Report.ps1 -SaveBaseline` returns no Secure Score. **Cause:** Assessments are too recent to compute a score, or the account lacks **Security Reader**. **Fix:** Allow assessment warm-up; confirm the account has at least Security Reader; re-run. If still empty, verify CSPM is enabled on the subscription.

Script cannot authenticate or query Resource Graph

Symptom: `DEFCSPMG-*.ps1` fails on connect, or the Resource Graph hunt errors. **Cause:** The Az modules (`Az.Accounts`, `Az.Security`, `Az.ResourceGraph`) are missing, the account is not signed in, or it lacks read access at scope. **Fix:** Let the script install the modules (it checks on run); `Connect-AzAccount -Environment AzureUSGovernment` and `Set-AzContext` to the pilot subscription; confirm Security Reader (or higher). Re-run the script. *(GCC High/DoD: the scripts default to the US Gov cloud — `-Environment AzureUSGovernment`. If you connect manually, always include that switch or the Az context targets commercial Azure and returns nothing.)*

7. Best Practices — Microsoft Defender for Cloud: CSPM & Secure Score Remediation

Field-proven guidance for running a posture-management program that measurably raises Secure Score without surprises.

Enable on a pilot subscription, then inherit at management-group scope

- Turn on Defender CSPM and agentless scanning on `CSPM Scope – Pilot Sub – Pilot` first, validate the cost and the recommendation picture, then enable at a **management-group** scope so new subscriptions inherit posture automatically.
- Preview every plan change with `DEFCSPMG-Enable-CSPM.ps1` (`-WhatIf` default) before applying.

Remediate by risk, not by count

• Work **attack paths** and highest-impact recommendations first — a single choke point on an internet-exposure → identity → sensitive-data path removes more real risk than clearing dozens of low-severity items.

• Use the built-in **Fix** action where offered, but do manual remediation of production resources in a controlled window with a rollback.

Treat Secure Score as a trend

• Capture a **baseline** (`DEFCSPMG-Report.ps1 -SaveBaseline`) and track the delta each cycle. A rising trend is the signal the program is working; a single snapshot is not.

• Re-baseline after each expansion wave so the trend reflects real scope growth, not just the pilot.

Make exemptions honest and time-bound

• Every exception is a scoped **exemption** with a **justification and expiry** (`CSPM Exemption – <recommendation> – Prod`) — never a silent suppression. Review exemptions on a cadence so they don't become permanent blind spots.

• Whether an exemption is *acceptable* is the security/compliance team's decision; the tooling records and expires it.

Assign ownership with governance rules

• Use `Secure Score Remediation – Pilot Sub – Prod` to assign **owners and due dates** to recommendations. Posture only improves when someone owns each finding; governance rules make that explicit and trackable.

Export continuously and report the trend

• Stream recommendations and Secure Score to Log Analytics (`CSPM Continuous Export – Pilot Sub – Prod`) and trend them in the `Secure Score Trend – Pilot Sub – Prod` workbook. This turns posture from a portal glance into a reportable metric for leadership.

Keep licensing and preview facts current (GCC High/DoD parity)

• **Defender CSPM, agentless scanning, and several plans are paid** and version-dependent. Before enabling, **verify current pricing and availability in your tenant** — never assume a feature is free or included.

• **In GCC High/DoD, feature and plan parity can lag commercial.** Agentless/data-aware posture, attack-path analysis, certain data connectors, AWS/GCP multicloud connectors, and preview capabilities **may be delayed or unavailable** in the sovereign cloud. Confirm each **against current Microsoft Government documentation** for your specific cloud (GCC High vs DoD/IL5) — see `gcc-high-parity-notes.md`. Do not assert parity or invent availability.

Defer the compliance and risk decisions to the owners

• Which **regulatory standards** apply, which **records/legal** obligations must be met, and whether a given **exemption or residual risk** is acceptable are the **compliance, legal, and security teams'** determinations. This solution delivers the controls, the scoring, and the evidence — not the decision.

Where to go next

Once CSPM is running and Secure Score is trending up, natural next steps in the catalog:

• **Azure Security Baseline & Governance** to enforce secure configuration with Azure Policy guardrails (audit → deny).

• **Microsoft Defender XDR Deployment & Unified Onboarding** to correlate endpoint/identity/email/cloud threat detection alongside posture.

• The **Sentinel** solutions to stream Defender for Cloud alerts into a SIEM for hunting and SOAR.

• **AWS/GCP** landing-zone and security-hub solutions to deepen multicloud coverage beyond high-level posture.

8. Deliverables Summary — Microsoft Defender for Cloud: CSPM & Secure Score Remediation

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What Defender for Cloud CSPM is — foundational vs Defender CSPM, Secure Score, agentless scanning, attack paths, compliance dashboard, multicloud; benefits, limitations
2. Requirements Guide	Solution-specific prerequisites with Verify / Implement-if-missing
Global Requirements (Defender)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered portal steps — enable CSPM, agentless scanning, compliance dashboard, prioritized remediation, governance, continuous export, pilot-first
5. Testing Guide	Eight validation tests with pass/fail gates
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations and where to go next
GCC High Parity Notes	National-cloud endpoints, feature-parity considerations, and compliance/data-residency context for the Government (GCC High) edition

PowerShell scripts (Az + KQL / Azure Resource Graph)

Script	What it does
`DEFCSPMG-Discovery.ps1`	Read-only posture discovery — Defender for Cloud plan tiers per subscription, Secure Score, registered providers, Log Analytics workspaces, and existing AWS/GCP connectors
`DEFCSPMG-Validate.ps1`	Confirms Defender CSPM on, agentless scanning enabled, provider registered, governance rule present, and continuous export configured
`DEFCSPMG-Report.ps1`	Secure Score + top recommendations report with drift versus a saved baseline (measures whether remediation is raising the score)
`DEFCSPMG-Enable-CSPM.ps1`	`-WhatIf`-gated helper that enables the Defender CSPM plan on a subscription (safe preview by default)
`DEFCSPMG-Hunt.ps1`	Runs KQL via Azure Resource Graph (`securityresources`) to query recommendations and attack paths (read-only)

What the buyer receives

- This solution as a branded **Word** document and **PDF**.
- All five **PowerShell scripts** (with embedded KQL / Resource Graph queries) in a single ZIP.
- A repeatable process following the model **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** — pilot-subscription first, every change preview/`-WhatIf` first, with a documented rollback.

Delivered as a **Complete Solution Package (PDF + Word + scripts)**.

Outcome

A continuous, prioritized view of cloud posture and a remediation cadence that measurably raises Secure Score — Defender for Cloud CSPM enabled, agentless scanning and the compliance dashboard on, attack paths remediated by risk, governance and exemptions tracked, and posture trended via continuous export — proven on a pilot subscription before you scale, including to AWS/GCP.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

DEFCSPMG-Discovery.ps1

Purpose: Read-only discovery for the "Microsoft Defender for Cloud — CSPM & Secure Score Remediation" solution. For the subscription in context (or a named subscription), lists the Defender for Cloud pricing/plan tiers (incl. CloudPosture / Defender CSPM), the current Secure Score, whether the Microsoft.Security provider is registered, available Log Analytics workspaces, and any existing AWS/GCP security connectors. Makes no changes. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Discovery.ps1 -SubscriptionId '<sub id>' Requires Az.Accounts, Az.Security, Az.Resources, Az.OperationalInsights. Government (GCC High): connects to the US Gov cloud. Run Connect-AzAccount -Environment AzureUSGovernment first, or the script will prompt. EXPECTED RESULTS A per-subscription readiness picture: plan tiers, Secure Score, provider state, workspaces, and connectors — the state to confirm before enabling Defender CSPM and remediating. .NOTES Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. Read-only. Reports configuration/identifiers only; makes no changes. Plan/pricing facts are indicative — verify current availability in your tenant. > [CmdletBinding()] param([string]$SubscriptionId, [string]$OutputPath = ".\DEFCSPMG-discovery.json")

How to run: powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Discovery.ps1 -SubscriptionId '<sub id>' Requires Az.Accounts, Az.Security, Az.Resources, Az.OperationalInsights. Government (GCC High): connects to the US Gov cloud. Run Connect-AzAccount -Environment AzureUSGovernment first, or the script will prompt. EXPECTED RESULTS A per-subscription readiness picture: plan tiers, Secure Score, provider state, workspaces, and connectors — the state to confirm before enabling Defender CSPM and remediating. .NOTES Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. Read-only. Reports configuration/identifiers only; makes no changes. Plan/pricing facts are indicative — verify current availability in your tenant. > [CmdletBinding()] param([string]$SubscriptionId, [string]$OutputPath = ".\DEFCSPMG-discovery.json")

DEFCSPMG-Enable-CSPM.ps1

Purpose: Change helper for the "Microsoft Defender for Cloud — CSPM & Secure Score Remediation" solution. Sets the Defender for Cloud CloudPosture (Defender CSPM) plan to Standard on the target subscription so agentless scanning, attack paths, and risk hunting unlock. This is the only script that can change configuration, and it DEFAULTS TO A SAFE PREVIEW. HOW TO RUN Preview (default — shows current vs intended, changes nothing): powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Enable-CSPM.ps1 -SubscriptionId '<pilot sub>' Apply (explicit — required to make the change): powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Enable-CSPM.ps1 -SubscriptionId '<pilot sub>' -Apply Requires Az.Accounts, Az.Security and Security Admin / Owner at the subscription. EXPECTED RESULTS Preview: prints the current CloudPosture tier and that it WOULD be set to Standard. Apply: sets the plan to Standard and confirms. Pilot first; Defender CSPM is a PAID plan —

verify current pricing/availability in your tenant before applying. .NOTES Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. DEFAULTS TO -WhatIf/preview. Defender CSPM is paid — cost applies on Apply. > [CmdletBinding()] param([Parameter(Mandatory)] [string]$SubscriptionId, [switch]$Apply)

How to run: Preview (default — shows current vs intended, changes nothing): powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Enable-CSPM.ps1 -SubscriptionId '<pilot sub>' Apply (explicit — required to make the change): powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Enable-CSPM.ps1 -SubscriptionId '<pilot sub>' -Apply Requires Az.Accounts, Az.Security and Security Admin / Owner at the subscription. EXPECTED RESULTS Preview: prints the current CloudPosture tier and that it WOULD be set to Standard. Apply: sets the plan to Standard and confirms. Pilot first; Defender CSPM is a PAID plan — verify current pricing/availability in your tenant before applying. .NOTES Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. DEFAULTS TO -WhatIf/preview. Defender CSPM is paid — cost applies on Apply. > [CmdletBinding()] param([Parameter(Mandatory)] [string]$SubscriptionId, [switch]$Apply)

DEFCSPMG-Hunt.ps1

Purpose: Read-only hunting/reporting for the "Microsoft Defender for Cloud — CSPM & Secure Score Remediation" solution. Runs KQL against the Azure Resource Graph 'securityresources' table to list, by risk, the open security recommendations (-Mode Recommendations) or the attack paths / high-risk items (-Mode AttackPaths, a Defender CSPM feature). Makes no changes. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Hunt.ps1 -Mode Recommendations powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Hunt.ps1 -Mode AttackPaths Requires Az.Accounts and Az.ResourceGraph. Government (GCC High): run Connect-AzAccount -Environment AzureUSGovernment first, or it will prompt into the US Gov cloud. EXPECTED RESULTS Recommendations: a ranked list of unhealthy security assessments (name, severity, resource). AttackPaths: the attack-path / high-risk records from the cloud security graph (Defender CSPM). Empty AttackPaths output usually means Defender CSPM is not yet active or warmed up. .NOTES Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. Read-only. The embedded KQL only reads posture data via Resource Graph. > [CmdletBinding()] param([ValidateSet('Recommendations','AttackPaths')] [string]$Mode = 'Recommendations', [int]$Top = 25)

How to run: powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Hunt.ps1 -Mode Recommendations powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Hunt.ps1 -Mode AttackPaths Requires Az.Accounts and Az.ResourceGraph. Government (GCC High): run Connect-AzAccount -Environment AzureUSGovernment first, or it will prompt into the US Gov cloud. EXPECTED RESULTS Recommendations: a ranked list of unhealthy security assessments (name, severity, resource). AttackPaths: the attack-path / high-risk records from the cloud security graph (Defender CSPM). Empty AttackPaths output usually means Defender CSPM is not yet active or warmed up. .NOTES Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. Read-only. The embedded KQL only reads posture data via Resource Graph. > [CmdletBinding()] param([ValidateSet('Recommendations','AttackPaths')]

[string]$Mode = 'Recommendations', [int]$Top = 25)

DEFCSPMG-Report.ps1

Purpose: Read-only reporting for the "Microsoft Defender for Cloud — CSPM & Secure Score Remediation" solution. Reports the current Secure Score, a count of unhealthy security assessments (open recommendations), and the top unhealthy assessments by name. If -BaselinePath points to a JSON file from a previous run, reports the DRIFT (score delta and change in open recommendations) so you can prove remediation is working. With -SaveBaseline, writes this run for next-cycle comparison. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Report.ps1 powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Report.ps1 -BaselinePath .\defcspm-baseline.json -SaveBaseline Requires Az.Accounts, Az.Security. EXPECTED RESULTS A posture report: Secure Score (current/max/percent), open-recommendation count, top unhealthy assessments, and — with a baseline — a drift line showing the improvement. .NOTES Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. Read-only. > [CmdletBinding()] param([string]$SubscriptionId, [string]$BaselinePath, [switch]$SaveBaseline, [int]$TopRecommendations = 10)

How to run: powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Report.ps1 powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Report.ps1 -BaselinePath .\defcspm-baseline.json -SaveBaseline Requires Az.Accounts, Az.Security. EXPECTED RESULTS A posture report: Secure Score (current/max/percent), open-recommendation count, top unhealthy assessments, and — with a baseline — a drift line showing the improvement. .NOTES Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. Read-only. > [CmdletBinding()] param([string]$SubscriptionId, [string]$BaselinePath, [switch]$SaveBaseline, [int]$TopRecommendations = 10)

DEFCSPMG-Validate.ps1

Purpose: Read-only validation for the "Microsoft Defender for Cloud — CSPM & Secure Score Remediation" solution. For the subscription in context (or a named subscription), checks: - Defender CSPM (CloudPosture) plan = Standard/On - Agentless scanning enabled in the CSPM plan extensions - Microsoft.Security provider registered - At least one governance rule present (best-effort via REST) - At least one continuous-export automation configured Prints a PASS/FAIL line per check. Makes no changes. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Validate.ps1 powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Validate.ps1 -SubscriptionId '<sub id>' Requires Az.Accounts, Az.Security, Az.Resources. EXPECTED RESULTS A checklist of PASS/FAIL results confirming the pilot subscription is correctly configured before you expand across the estate. .NOTES Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. Read-only. > [CmdletBinding()] param([string]$SubscriptionId)

How to run: powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Validate.ps1 powershell -ExecutionPolicy Bypass -File .\DEFCSPMG-Validate.ps1 -SubscriptionId '<sub id>' Requires Az.Accounts, Az.Security, Az.Resources. EXPECTED RESULTS A checklist of PASS/FAIL results confirming the pilot subscription is correctly configured before you expand across the estate. .NOTES

Government (GCC High) edition: targets the US Gov cloud via Connect-AzAccount -Environment AzureUSGovernment. Plan/feature availability in GCC High/DoD may lag commercial — verify against current Microsoft Government documentation. White-label. Read-only. > [CmdletBinding()] param([string]$SubscriptionId)